

# **Northgate Settlement Services Ltd - Security and Operational Resilience**

## **Security Governance and Certification**

Northgate has held ISO 27001 certification continuously since 2020. The current certificate, issued March 2025, is provided at Appendix D. The most recent surveillance audit raised no major non-conformities.

A dedicated Chief Information Security Officer was appointed in 2021 and reports to the board risk committee, independently of the technology delivery function.

## Technical Controls

Data in transit is encrypted using TLS 1.3. Data at rest, including all production databases and backups, is encrypted using AES-256 with keys managed in a FIPS 140-2 Level 3 hardware security module.

Access follows least-privilege provisioning. Multi-factor authentication is enforced for all accounts without exception. Privileged access is time-bound and session-recorded. Access recertification is quarterly and evidenced.

Critical vulnerabilities are remediated within 7 days and high severity within 30 days under a documented SLA. Compliance against that SLA was 100 per cent for critical and 97 per cent for high severity during 2025.

## **Testing and Assurance**

Independent penetration testing is performed twice annually. The most recent test, completed October 2025, identified two medium-severity and five low-severity findings. All seven were remediated by December 2025 and retest evidence confirming closure is provided at Appendix E.

Vulnerability scanning runs continuously against internet-facing systems and weekly against the internal estate.

## **Business Continuity and Disaster Recovery**

A documented business continuity plan and disaster recovery plan are maintained for all critical services and were last updated in January 2026.

Stated recovery objectives are a recovery time objective of 2 hours and a recovery point objective of 15 minutes for settlement services.

Full failover testing to the secondary site is performed twice yearly. The most recent test, in November 2025, achieved failover in 74 minutes against the 2 hour objective. The test report and lessons-learned log are provided.

A documented single points of failure analysis is maintained and reviewed annually. No unremediated single point of failure exists in any critical settlement path; dual correspondent banking and dual cloud regions provide redundancy.

## **Incident Management**

A documented incident management process defines severity classification, escalation paths and regulatory notification timelines.

One security incident was recorded in 2025: a phishing attempt that was blocked at the mail gateway with no account compromise. No client data was affected. A post-incident review was completed within 5 business days.